

Information Disclosure Vulnerabilities

Information disclosure

🚧 LAB	APPRENTICE Information disclosure in error messages →	✓ Solved
🚧 LAB	APPRENTICE Information disclosure on debug page →	✓ Solved
🚧 LAB	APPRENTICE Source code disclosure via backup files →	✓ Solved
🚧 LAB	APPRENTICE Authentication bypass via information disclosure →	✓ Solved
🚧 LAB	PRACTITIONER Information disclosure in version control history →	✓ Solved

SUMMARY

Information disclosure, also known as information leakage, is when a website unintentionally reveals sensitive information to its users

Examples

- Revealing the names of hidden directories, their structure, and their contents via a `robots.txt` file or directory listing.

- Providing access to source code files via temporary backups.
- Explicitly mentioning database table or column names in error messages.
- Unnecessarily exposing highly sensitive information, such as credit card details.
- Hard-coding API keys, IP addresses, database credentials, and so on in the source code.
- Hinting at the existence or absence of resources, usernames, and so on via subtle differences in application behavior.

How do they arise?

Failure to remove internal content from public content.

Insecure configuration of the website and related technologies.

Flawed design and behavior of the application

Whenever while testing websites follow basic recon methodology

And check if query string parameters which represent any id are up there in url

If suppose id = 1 or of int/number type

Change the type(like it to a string) and check the response of id parameter.

unexpected data type causes an exception, and a full stack trace is displayed in the response.

Use Logger++

A built in grep tool allows the logs to be searched to locate entries which match a specified pattern, and extract the values of the capture groups.

Use Engagement tools as they help in discovering content, webservices, comments,sensitive files and references when in Target> Sitemap.

Check is server side checks implemented for accessing the files that are disallowed in robots.txt

Check if are you able to access /admin (admin panel)

So basically you are doing a GET /admin

But in this scenario change it to TRACE /admin

TRACE is an HTTP method used for **diagnostic purposes**.

When you send a TRACE request, the server returns the **exact request** it received — headers, body, everything.

It enables Cross-Site Tracing (XST)

If a browser allows TRACE and the server responds to it, attackers can potentially steal:

- Cookie
- Authentication tokens
- Sensitive headers (Authorization, X-CSRF-Token, etc.)

TRACE reveals

- Proxy-added headers
- IP chain
- Internal network information
- Debug info left by developers

X-Custom-IP-Authorization is a **non-standard, custom HTTP header** used by some poorly configured applications to make “IP-based access decisions.

This is usually meant for:

- Allowing internal admins to bypass auth
- Letting internal systems talk to each other
- Granting elevated permissions to whitelisted IPs

But since **anyone can modify headers**, attackers can simply spoof it.

Bypass Authentication

If an app trusts this header, you can do:

X-Custom-IP-Authorization: 127.0.0.1

X-Custom-IP-Authorization: 127.0.0.1

Boom — you appear as localhost.

Some apps instantly give admin access.

2. Bypass IP restrictions

Blocked endpoint?

403 Forbidden – Your IP is not allowed

Just spoof:

X-Custom-IP-Authorization: 192.168.1.10

If backend trusts it → you're in.

3. Bypass WAF rules

A few bad architectures use this header to allow "internal" traffic to skip WAF filtering.

Spoofing the header might disable protections.

4. Privilege escalation

Some APIs use internal IP checks to allow admin actions:

/api/debug

/api/v1/admin

/api/system/reboot

And trust this header to validate IP.

You can jump from normal user → admin instantly.

When you jump to a website try to browse for /.git to reveal git version control data

wget -r url (wget -r is used to recursively download an entire website or directory structure)

GitDumper is a tool from **GitTools** that allows you to **download a website's exposed .git directory** and reconstruct the full repository locally.

If a target leaks .git/ publicly, GitDumper can pull:

- Source code
- Secrets
- Commit history
- Credentials
- API keys
- Old versions of files (goldmine for pentesters)

